Protection Needs Elicitation (PNE) & CIA Triad Mapping Report

Course: CYC386 Secure Software Design and Development | **Sprint:** Midterm Lab Exam (Fall 2026)
Instructor: Engr. Muhammad Ahmad Nawaz | **Team:** Muhammad Tallat (FA23-BCT-029), Sadat Ali (FA23-BCT-034), Hassaan Shakoor (FA23-BCT-054)

1. Executive Summary

In accordance with CDF Unit 2, this document establishes the asset inventory, stakeholder perspectives, and explicit mapping to the Confidentiality, Integrity, and Availability (CIA) triad for the CloudVault platform. Every elicited protection need serves as the foundational justification for threat modeling, engineering remediations, and automated test gates.

2. Asset Inventory

• **DA-01 User Credentials & Tokens:** Passwords, session cookies, bearer tokens.
• **DA-02 Confidential Documents:** Proprietary project files, audit forecasts.
• **DA-03 Document Metadata:** Author identities, creation timestamps, classification flags.
• **DA-04 Security Audit Logs:** Records of authentication, access attempts, and administrative actions.
• **PA-01 to PA-05:** Authentication, native header parsing, network diagnostics, object-level access control, and ownership transfer.
• **CA-01 to CA-04:** Flask web container, SQLite/PostgreSQL database, native shared library, and host operating system.

3. Explicit CIA Triad Mapping & Requirements Derivation

Need ID	Asset	Protection Need	CIA	Security Requirement
PN-01	DA-01	Protect passwords and session tokens	**Confidentiality**	SR-01: Hash with PBKDF2/Argon2. Cookies with SameSite=Strict.
PN-02	DA-02	Confidential files restricted to owners	**Confidentiality**	SR-02: Enforce doc.owner_id == user.id (Assert 403).
PN-03	PA-05	Transfers require verified intent	**Integrity**	SR-03: Validate anti-CSRF synchronizer token.
PN-04	CA-04	Host shell protected from inputs	**Integrity / Avail**	SR-04: subprocess.run(shell=False) + regex whitelist.
PN-05	CA-03	Native parser memory safety	**Integrity / Avail**	SR-05: Bounded memcpy/snprintf + stack canaries.
PN-06	CA-01	Anti-framing defense on admin panel	**Integrity / Conf**	SR-06: X-Frame-Options: DENY and CSP frame-ancestors.
PN-07	DA-04	Tamper-evident audit logging	**Integrity**	SR-07: Log timestamp, actor, action, IP in DB.
PN-09	CA-01	Automated security gating	**Integrity / Avail**	SR-09: Fail CI/CD build on Critical/High findings.